

Northgate University

# Access Control Policy

An ISO/IEC 27001:2013 aligned document · Internal Use Only

|                    |                                    |
|--------------------|------------------------------------|
| Document Reference | NGU-POL-9.1                        |
| Version            | 1.0                                |
| Classification     | Internal Use Only                  |
| Issue Date         | 01 June 2026                       |
| Policy Owner       | Chief Information Security Officer |
| Approved By        | Information Governance Board       |
| Next Review Date   | 01 June 2027                       |
| Aligned Standard   | ISO/IEC 27001:2013 — Annex A.9     |

## 1. Purpose

This policy defines how Northgate University ("the University") controls access to its information, systems, and services, ensuring that access is granted only to authorised individuals on the basis of business need and removed when no longer required. It supports the protection of the confidentiality, integrity, and availability of University information in line with ISO/IEC 27001:2013 Annex A.9.

## 2. Scope

This policy applies to all University information systems, applications, networks, and services, and to all staff, students, contractors, and third parties granted access to them. It covers access from University and personal devices and from on-site, remote, and cloud-hosted environments.

## 3. Access Control Principles

Access to University information and systems is governed by the following principles:

- **Least privilege.** Users are granted the minimum access required to perform their role.
- **Need-to-know.** Access to information is based on a legitimate requirement to use it.
- **Role-based access.** Access rights are assigned according to defined roles wherever practicable.
- **Segregation of duties.** Conflicting responsibilities are separated to reduce the risk of error or misuse.
- **Default deny.** Access is denied unless it has been explicitly authorised.

## 4. Network and Service Access

Access to University networks and network services is restricted to authorised users and devices. Users are provided access only to the networks and services they are specifically authorised to use, and network access is protected by appropriate authentication (ISO/IEC 27001:2013 A.9.1).

## 5. User Access Management

- **Unique identity.** Every user is issued a unique user ID; generic or shared accounts are prohibited except where formally approved and individually accountable.
- **Provisioning.** Access is granted only following formal, documented approval by the relevant Information Asset Owner or line manager.
- **Privileged access.** Administrative and other privileged access is restricted to named individuals, approved separately, used only when required, and logged and monitored.
- **Access reviews.** User access rights are reviewed at least every six months, and privileged access more frequently, by the relevant owner.
- **Leavers and movers.** Access is removed promptly when a user leaves the University and adjusted without delay when a user changes role (A.9.2.6).

## 6. Authentication Standards

All access to University systems is authenticated. The following minimum standards apply:

| Control                                  | Requirement                                                                                                                                                  |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Multi-factor authentication (MFA)</b> | Required for all remote access, all privileged and administrative accounts, and all access to Confidential information.                                      |
| <b>Minimum password length</b>           | At least 12 characters; passphrases are encouraged.                                                                                                          |
| <b>Credential storage</b>                | Passwords are stored only in salted, hashed form and are never held or transmitted in plaintext.                                                             |
| <b>Account lockout</b>                   | Accounts are temporarily locked after a defined number of consecutive failed log-on attempts.                                                                |
| <b>Password change</b>                   | Passwords are changed when compromise is known or suspected; mandatory periodic expiry is not enforced for its own sake, in line with current good practice. |
| <b>Shared credentials</b>                | Sharing of credentials is prohibited except for formally approved, individually accountable service accounts.                                                |

## 7. User Responsibilities

- Keep authentication credentials confidential and never share them.
- Use unique credentials for University accounts and do not reuse them on external services.
- Lock or log off unattended sessions.
- Report suspected credential compromise or unauthorised access immediately (A.9.3).

## 8. System and Application Access Control

- **Information access restriction.** Access within systems is restricted in line with the access control principles and information classification.
- **Secure log-on.** Systems enforce secure log-on procedures, including MFA where required, and limit the information displayed before successful authentication.

- **Privileged utilities.** Use of utility programs capable of overriding system or application controls is restricted and logged.
- **Source code access.** Access to program source code and development environments is restricted to authorised personnel (A.9.4).

## 9. Remote and Third-Party Access

Multi-factor authentication is mandatory for all remote access to University systems. Remote access is further governed by the Remote Working Policy (NGU-POL-6.2). Third-party access is granted only under the Supplier Security Policy (NGU-POL-15.1), is time-bound, and is subject to the same access controls and monitoring as University users.

## 10. Logging and Monitoring

Access to University systems and information is logged. Logs of privileged access and access to Confidential information are reviewed regularly, and anomalies are investigated as potential security incidents in accordance with the Information Security Incident Management Policy (NGU-POL-16.1).

## 11. Roles and Responsibilities

- **Chief Information Security Officer (CISO).** Owns this policy and defines access control standards.
- **Information Asset Owners (IAOs).** Approve and review access to their information assets.
- **IT Service and System Administrators.** Provision, adjust, and remove access in line with approvals, and operate authentication and logging controls.
- **Line Managers.** Request appropriate access for their staff and notify of leavers and movers.
- **All users.** Comply with this policy and protect their credentials.

## 12. Compliance and Enforcement

Compliance with this policy is mandatory. Attempting to gain or grant unauthorised access is a serious breach that may result in disciplinary action, removal of access, and, where appropriate, referral to law enforcement. For third parties, non-compliance may constitute a breach of contract.

## 13. Related Policies and Standards

- Information Security Policy (NGU-POL-5.1)
- Information Classification Policy (NGU-POL-8.2)
- Remote Working Policy (NGU-POL-6.2)
- Supplier Security Policy (NGU-POL-15.1)
- Information Security Incident Management Policy (NGU-POL-16.1)
- ISO/IEC 27001:2013 — Annex A.9 (A.9.1–A.9.4)
- ISO/IEC 27002:2013 (implementation guidance)

## 14. Document Version History

| Version | Date         | Author                             | Summary of Change                                                                 |
|---------|--------------|------------------------------------|-----------------------------------------------------------------------------------|
| 1.0     | 01 June 2026 | Chief Information Security Officer | Initial issue. Establishes access control requirements across University systems. |